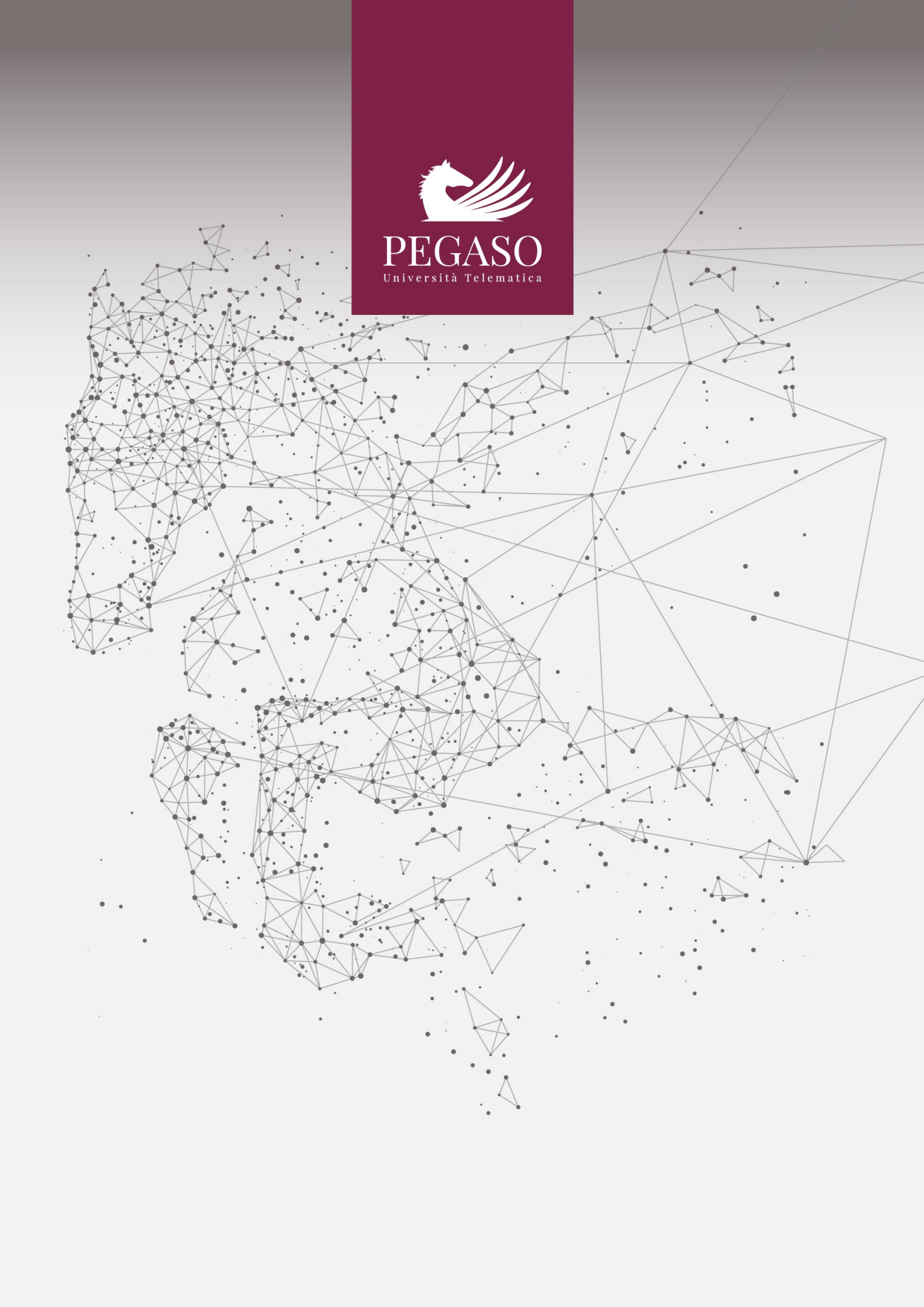

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 LE PRIME SANZIONI 3

2 IN ITALIA 8

3 LE ULTIME SANZIONI CONTRO I GIGANTI DEL WEB 15

BIBLIOGRAFIA 16

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Le prime sanzioni

Il Regolamento UE 679/2016 (GDPR) contiene un meccanismo sanzionatorio particolarmente oneroso per i titolari del trattamento che contravvengano alla disciplina a protezione dei dati personali degli individui. L'articolo 83 prevede due tipi di sanzioni:

1. Sanzioni di minore gravità, che possono raggiungere cifre fino ai 10 milioni di euro o 2% del fatturato globale dell'esercizio precedente, in base a quale delle due somme sia superiore;
2. Sanzioni di maggiore gravità, fino a 20 milioni o 4 % del fatturato.

Nell'Unione Europea fin dal momento dell'entrata in vigore del GDPR si è dunque messa in moto una intensa attività da parte delle Autorità garanti per la privacy di sanzione delle imprese che non rispettassero i dettami stringenti della nuova normativa.

In Germania, nel novembre 2018 il social "Knuddels.de" è stato condannato al pagamento di 20.000 euro per aver violato l'articolo 32 del GDPR. La piattaforma era infatti stata vittima di un data breach di 2 milioni di username/password e di più di 800 mila e-mail, oltre ad indirizzi di residenza degli utenti ed altri tipi di dati. Il problema censurato dal garante tedesco era che Knuddels.de non aveva messo a punto misure tecniche di protezione adeguate per fronteggiare un simile rischio: i dati personali degli utenti erano infatti conservati in chiaro. Tuttavia, l'importo della multa è stato quantificato in una cifra piuttosto bassa grazie alla collaborazione di Knuddels.de nell'attività ispettiva del garante in merito alla vicenda.

In Portogallo, invece, il Centro Hospitalar Barreiro Montijo ha sofferto una sanzione ben più grave di 400.000 euro per:

- mancato rispetto della confidenzialità e limitazione degli accessi ai dati dei soggetti ricoverati (i dati dei pazienti riservati al personale medico erano accessibili a assistenti sociali);

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- non aver predisposto policy o adottato strumenti tecnici che permettessero la diversificazione degli accessi).

In questo caso, nella quantificazione della sanzione il garante portoghese ha tenuto conto della tipologia di dati coinvolti (dati riguardanti la salute, quindi particolari), della durata nel tempo della violazione, del numero di interessati e della gravità dei danni subiti.

La Commission nationale de l'Informatique (CNIL), garante francese, nel gennaio 2019 ha inflitto una multa record a Google: 50 milioni di euro per violazioni degli obblighi di trasparenza (articolo 12 GDPR), informativa (art. 13 del RGPD) e determinazione di idonea base giuridica (art. 6, paragrafo 1, del RGPD). Infatti, il CNIL ha riscontrato:

- Mancanza di trasparenza nell'informativa resa agli utenti: informazioni essenziali come le finalità dell'elaborazione dei dati, il periodo in cui vengono immagazzinati e le categorie dei dati personali utilizzati per la personalizzazione delle inserzioni pubblicitarie non erano facilmente accessibili;
- Violazione delle disposizioni in materia di consenso: il percorso guidato della piattaforma induceva il cliente a creare un account Google.

Nell'estate del 2019 l'Information Commissioner's Office (ICO), garante inglese, ha comminato una sanzione di 183 milioni di sterline, pari a circa 200 milioni di euro, alla compagnia British Airways, a causa di un data breach avvenuto nel 2018. Era stato quindi violato l'articolo 32 del GDPR, con deviazione del traffico degli utenti su un sito fake e acquisizione di dati di carte di credito di 500.000 clienti. La compagnia aveva notificato la violazione entro i tempi previsti dal GDPR (72 ore dall'evento), aveva supportato i clienti coinvolti e collaborato con l'ICO. Tuttavia, la gravità del breach e del rischio per gli interessati, resi possibili dalla carenza di misure di sicurezza adottate dalla British Airways, ha portato l'Autorità a imporre la sanzione stellare, nonostante il comportamento della compagnia a seguito della violazione.

Nel 2020 l'Autorità garante belga ha imposto a un'azienda una sanzione di 50.000 euro per violazione della normativa sull'indipendenza del Data Protection Officer (DPO) dettata dall'articolo

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

38 del GDPR. Il garante ha infatti affermato che il professionista incaricato si trovava in una posizione di conflitto d'interessi, dato che ricopriva allo stesso tempo anche il ruolo di direttore dei dipartimenti di compliance, risk management e internal audit. Tale provvedimento si inquadra in una lunga serie di riflessioni sul ruolo del DPO all'interno dell'impresa e sulla possibilità di nominare un soggetto che ricopre già posizioni apicali, dotate di poteri decisionali che potrebbero confliggere con il ruolo di responsabile per la protezione dei dati personali, avvicinandolo pericolosamente alla posizione del titolare del trattamento.

Nel maggio 2020, il Garante finlandese ha comminato le sue prime quattro sanzioni:

- 100.000 euro al servizio postale Posti Oy, per mancanza di trasparenza nel trattamento dei dati;
- 16.000 euro a una compagnia comunale per non aver effettuato una DPIA quando invece era necessario;
- 12.500 euro a una compagnia per aver utilizzato dei moduli per la presentazione di domande di lavoro come mezzi per raccogliere informazioni sulle confessioni religiose, sulla salute e sulle possibili gravidanze e situazioni familiari dei candidati;
- 72.000 euro alla compagnia Taxi Helsinki Oy, per varie violazioni del GDPR.

In particolare, nel caso di Taxi Helsinki Oy, la compagnia violava la privacy dei propri clienti per via delle telecamere di videosorveglianza installate negli autoveicoli, per le quali non era stata data l'adeguata informativa agli interessati né era stato indicato in alcun modo dove fosse possibile reperire tali informazioni. Inoltre, la registrazione non solo del video ma anche dell'audio violava il principio di minimizzazione del trattamento: l'audio non era necessario per raggiungere la finalità del trattamento enunciata dal titolare, ovvero garantire la sicurezza dei tassisti.

Il 14 maggio 2020 l'Autorità garante del Belgio ha sanzionato una piattaforma social per violazione dell'articolo 6 del GDPR: mandava inviti a contatti dei suoi utenti senza il loro consenso e senza avere un'altra base giuridica. Nella sua pronuncia il garante ha espresso alcuni principi di interpretazione della normativa di data protection e che devono essere ritenuti validi in tutto il

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

territorio dell'Unione. In particolare, ha stabilito che la funzione "invita un amico" è possibile solo a determinate condizioni e che non è possibile inviare una e-mail informativa per chiedere il consenso a ricevere successive comunicazioni commerciali.

Nell'ambito delle attività di social network, spesso gli utenti si trovano a dare il consenso all'accesso ai contatti della propria rubrica. Il Garante ha specificato che tale consenso non può essere usato per trattare i dati degli utenti presenti nella rubrica, perché solo l'interessato può dare il consenso al trattamento dei dati che lo riguardano. Per quanto riguarda il legittimo interesse della piattaforma social, che può essere usato come base giuridica del trattamento alternativa al consenso, si configura la regola del "confronta e dimentica": la piattaforma può usare i dati presenti nella rubrica per fare un controllo sui contatti dell'utente al fine di stabilire se tra questi ci sono utenti registrati sul social che hanno prestato il proprio consenso al trattamento. Se la verifica dà esito positivo, la base giuridica del trattamento dei dati degli utenti già registrati sarà il consenso che loro stessi hanno prestato. Se dà esito negativo, la piattaforma deve cancellare immediatamente i loro dati.

La funzione "invita amici" è sottoposta a quattro condizioni che devono sussistere simultaneamente:

1. Non c'è nessun incentivo a mittente o destinatario;
2. È il singolo utente a scegliere chi riceve la comunicazione (e la piattaforma non può «pre-flaggare» tutti i destinatari);
3. L'identità del mittente è in chiaro;
4. Il mittente conosce l'intero contenuto del messaggio inviato per suo conto.

In questi casi il messaggio di invito diventa una vera e propria "comunicazione personale", dunque si esce dall'ambito di applicazione della normativa del GDPR.

Per quanto riguarda l'invio di e-mail commerciali, il Garante ha stabilito che non è lecito, ai sensi del GDPR, inviare una e-mail finalizzata esclusivamente a chiedere il consenso per l'invio

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

successivo di comunicazioni commerciali. Per l'invio di e-mail di marketing, infatti, è necessario il consenso preventivo dell'interessato.

Il Garante ungherese ha imposto una sanzione di 290.000 euro (record in Ungheria) al provider di servizi di comunicazione Digi Zrt. Tale sito, infatti, si basava su un sistema di open source che conteneva dati identificativi (compresi indirizzi bancari) vulnerabili ad attacchi informatici e furto d'identità. Digi era a conoscenza della vulnerabilità, aveva procedure e sistemi di sicurezza ma non erano effettivamente implementati. Tale provvedimento mette in luce alcuni aspetti interessanti:

- Essere formalmente in regola con il GDPR senza una effettiva implementazione dei sistemi di sicurezza non protegge dalle sanzioni;
- Anche se non c'è stato un effettivo furto di dati o un danno agli interessati, l'esistenza stessa di vulnerabilità nei sistemi di sicurezza può portare a sanzioni;
- La comunicazione tempestiva del data breach all'Autorità di controllo non è stato un fattore attenuante nella determinazione della sanzione;

Per i siti con molti visitatori è necessario uno standard di sicurezza più alto.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 In Italia

Il 4 aprile 2019 il Garante per la protezione dei dati personali ha sanzionato l'Associazione Rousseau per 50.000 euro per non aver rispettato le prescrizioni date dal Garante a seguito di un data breach che aveva colpito vari siti dell'Associazione, violando quindi l'articolo 32 del GDPR. In particolare, l'Autorità ha contestato:

- il mancato completo tracciamento degli accessi al database del sistema Rousseau e le garanzie di riservatezza inadeguate;
- la condivisione delle credenziali di autenticazione da parte di più incaricati e la mancata definizione e configurazione dei differenti profili di autorizzazione per limitare l'accesso ai soli dati necessari nei diversi ambiti di operatività.

Infatti, nel provvedimento si legge che:

"*1) il mancato, completo tracciamento degli accessi al database del sistema Rousseau e delle operazioni sullo stesso compiute (di cui alla specifica misura necessaria, tecnica e organizzativa, prescritta dall'Autorità con il provvedimento del 21 dicembre 2017 e oggetto di due proroghe) configura la violazione di quel generale dovere di controllo sulla liceità dei trattamenti che grava sul titolare del trattamento e, in particolare, dell'obbligo di assicurare più adeguate garanzie di riservatezza agli iscritti alla piattaforma medesima; ciò sia in ragione delle dimensioni delle banche dati in questione, sia della tipologia di dati raccolti nonché delle funzionalità che le caratterizzano (tra cui, in particolare, il sistema di e-voting che deve essere necessariamente assistito da idonei accorgimenti a tutela dei dati personali dei votanti). Ciò a maggior ragione tenendo conto che tali banche dati sono particolarmente esposte al rischio di attività di hakeraggio o comunque ad attacchi informatici, quali quelli verificatisi più volte, anche successivamente al data breach di agosto 2017;*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2) l'accertata condivisione delle credenziali di autenticazione da parte di più incaricati dotati di elevati privilegi per la gestione della piattaforma Rousseau e la mancata definizione e configurazione dei differenti profili di autorizzazione in modo da limitare l'accesso ai soli dati necessari nei diversi ambiti di operatività, nel previgente ordinamento erano addirittura qualificate come misure minime di sicurezza (cfr. regole nn. 2, 3 e 13 del disciplinare tecnico di cui all'allegato B del Codice) che i titolari del trattamento erano tenuti ad adottare al fine di assicurare un livello minimo di protezione dei dati personali. E' pertanto evidente come la mancata adozione di tali misure e, per converso, l'avvenuta condivisione delle credenziali di autenticazione tra più soggetti legittimati alla gestione della piattaforma rappresentino una violazione dell'obbligo di predisposizione, da parte del responsabile del trattamento, di misure tecniche e organizzative adeguate."

Nel gennaio 2020 il Garante ha imposto due sanzioni a ENI Gas e Luce, per un totale di 11,5 milioni di euro. In particolare, l'Autorità ha ravvisato che la compagnia effettuava:

- Telemarketing in mancanza di consenso;
- Assenza di misure tecniche e organizzative per recepire le manifestazioni di volontà degli utenti;
- Tempi di conservazione dei dati superiori a quelli consentiti;
- Trattamenti contrari a principi di correttezza, esattezza e aggiornamento dei dati.

Nel provvedimento, l'Autorità ha affermato:

"*La prima sanzione di 8,5 milioni di euro riguarda trattamenti illeciti nelle attività di telemarketing e teleselling riscontrati nel corso di accertamenti e ispezioni svolti dall'Autorità a seguito di diverse decine di segnalazioni e reclami, ricevuti all'indomani della piena applicazione del Gdpr.*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Dalle verifiche è emerso un circoscritto numero di casi rivelatori tuttavia di condotte "di sistema" poste in essere da Egl, che hanno evidenziato gravi criticità relative al generale trattamento dei dati.

Tra le violazioni messe in luce spiccano le telefonate pubblicitarie effettuate senza il consenso della persona contattata o nonostante il suo diniego a ricevere chiamate promozionali, oppure senza attivare le specifiche procedure di verifica del Registro pubblico delle opposizioni; l'assenza di misure tecnico organizzative in grado di recepire le manifestazioni di volontà degli utenti; tempi di conservazione dei dati superiori a quelli consentiti; l'acquisizione dei dati dei potenziali clienti da soggetti (list provider) che non avevano acquisito il consenso per la comunicazione di tali dati.

Il Garante, dopo aver dichiarato l'illiceità delle condotte rilevate, ha ingiunto a Egl di implementare procedure e sistemi per verificare, anche tramite l'esame di un campione rilevante di nominativi, lo stato dei consensi delle persone inserite nelle liste dei contatti, prima dell'inizio delle campagne promozionali. Egl dovrà inoltre provvedere alla definitiva automatizzazione dei flussi di dati dal proprio database alla black list di chi non vuole ricevere pubblicità in uso presso la società.

Il Garante, inoltre, ha vietato alla società l'uso dei dati forniti dai list provider senza che questi ultimi avessero acquisito uno specifico consenso alla loro comunicazione a Egl.

La seconda sanzione di 3 milioni di euro riguarda violazioni nella conclusione di contratti non richiesti nel mercato libero della fornitura di energia e gas. Molte persone si sono rivolte all'Autorità lamentando di aver appreso della stipula di un nuovo contratto solo dalla ricezione della lettera di disdetta del vecchio fornitore o dalle prime fatture di Egl. In alcuni casi poi le segnalazioni denunciavano la presenza nel contratto di dati inesatti e di sottoscrizione apocrifa.

Le gravi irregolarità hanno interessato circa 7200 consumatori. Dagli accertamenti dell'Autorità è emerso che le condotte adottate da Egl nell'acquisizione di nuovi clienti mediante alcune agenzie esterne operanti per suo conto, per modalità organizzative e gestionali, hanno determinato trattamenti non conformi al Regolamento UE, in quanto contrari ai principi di correttezza, esattezza e aggiornamento dei dati."

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nel febbraio 2020, il Garante ha comminato una sanzione di 27,8 milioni di euro a TIM, contestando alla compagnia:

- Mancanza di accountability;
- Mancanza di consenso per l'attività di marketing telefonico;
- Mancanza di trasparenza e informazioni non corrette nella gestione di alcune app;
- Inefficienza nella gestione di data breach;
- Violazione del principio di privacy by design.

Il Garante ha così ricostruito la vicenda:

"*Dal gennaio 2017 ai primi mesi del 2019, sono pervenute all'Autorità centinaia di segnalazioni relative, in particolare, alla ricezione di chiamate promozionali indesiderate effettuate senza consenso o nonostante l'iscrizione delle utenze telefoniche nel Registro pubblico delle opposizioni, oppure ancora malgrado il fatto che le persone contattate avessero espresso alla società la volontà di non ricevere telefonate promozionali. Irregolarità nel trattamento dei dati venivano lamentate anche nell'ambito dell'offerta di concorsi a premi e nella modulistica sottoposta agli utenti da Tim.*

Dalla complessa attività istruttoria che ne è derivata, svolta anche con il contributo del Nucleo Speciale Tutela Privacy e Frodi Tecnologiche della Guardia di Finanza, sono emerse numerose e gravi violazioni della disciplina in materia di protezione dei dati personali.

Tim ha dimostrato di non avere sufficiente contezza di fondamentali aspetti dei trattamenti di dati effettuati (accountability).

Tra i milioni di telefonate promozionali effettuate in sei mesi nei confronti di "non clienti" l'Autorità ha accertato che le società di call center incaricate da Tim hanno, in molti casi, contattato gli interessati senza il loro consenso. Una persona è stata chiamata 155 volte in un mese. In circa duecentomila casi, sono state contattate anche numerazioni "fuori lista", cioè non presenti

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

negli elenchi delle persone contattabili di Tim. Sono state rilevate poi altre condotte illecite come l'assenza di controllo da parte della società sull'operato di alcuni call center; l'errata gestione e il mancato aggiornamento delle black list dove vengono registrate le persone che non vogliono ricevere pubblicità; l'acquisizione obbligata del consenso a fini promozionali per poter aderire al programma "Tim Party" con i suoi sconti e premi.

Nella gestione di alcune app destinate alla clientela, inoltre, sono state fornite informazioni non corrette e non trasparenti sul trattamento dei dati e sono state adottate modalità di acquisizione del consenso non valide.In alcuni casi è stata utilizzata modulistica cartacea con richiesta di un unico consenso per diverse finalità, inclusa quella di marketing.

La gestione dei data breach non è poi risultata efficiente, così come inadeguate sono risultate l'implementazione e la gestione da parte della Società dei sistemi che trattano dati personali (con violazione del principio di privacy by design). Disallineamenti sono emersi tra le black list di Tim e quelle dei call center incaricati, così come per le registrazioni audio dei contratti stipulati telefonicamente (verbal order). Le utenze di clienti di altri operatori, detenute da Tim in quanto gestore delle Reti, sono state conservate per un tempo superiore ai limiti di legge e inserite, senza il consenso degli interessati, in alcune campagne promozionali.

Oltre alla sanzione, l'Autorità ha imposto a Tim 20 misure correttive, tra divieti e prescrizioni. In particolare, ha vietato a Tim l'uso dei dati a fini di marketing di chi aveva espresso ai call center il proprio diniego a ricevere telefonate promozionali, dei soggetti presenti in black list e dei "non clienti" che non avevano dato il consenso.

La società non potrà più utilizzare neanche i dati della clientela raccolti mediante le app "My Tim", "Tim Personal" e "Tim Smart Kid" per finalità diverse dall'erogazione dei servizi senza un consenso libero e specifico.

Fra le prescrizioni, il Garante ha ingiunto a Tim di verificare la consistenza delle black list utilizzate e di acquisire tempestivamente quelle eventualmente formate dai call center per riversarle nella propria black list. Tim dovrà inoltre rivedere il programma "Tim Party" e consentire

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

l'accesso dei clienti a sconti e concorsi a premi eliminando il consenso obbligato al marketing. L'azienda dovrà anche verificare la procedura per l'attivazione di tutte le app, specificare sempre, con linguaggio chiaro e comprensibile, i trattamenti svolti con l'indicazione delle finalità perseguite e delle modalità di trattamento utilizzate, nonché acquisire un valido consenso. La Società dovrà inoltre implementare le misure tecniche ed organizzative relative alla gestione delle istanze di esercizio dei diritti degli interessati e rafforzare le misure volte ad assicurare la qualità, l'esattezza e il tempestivo aggiornamento dei dati personali trattati dai diversi sistemi della società."

Sempre per telemarketing aggressivo è stata infine sanzionata Vodafone, nel novembre 2020. Anche in questo caso le violazioni riguardavano il consenso degli interessati, il principio di responsabilizzazione e quelli di privacy by design e by default. Il Garante ha così stabilito:

"*Gli accertamenti svolti dall'Autorità hanno evidenziato importanti criticità "di sistema" - che riguardano la violazione non solo dell'obbligo del consenso, ma anche dei fondamentali principi di responsabilizzazione e di implementazione delle tutele privacy fin dalla fase di progettazione dei trattamenti, stabiliti dal Regolamento Ue. Criticità riconducibili al complesso delle operazioni svolte dalla società nei confronti sia dell'intera base clienti di Vodafone, sia del più ampio ambito dei potenziali utenti del settore delle comunicazioni elettroniche.*

Nel corso dell'istruttoria è emerso, in particolare, un allarmante fenomeno di utilizzo di numerazioni fittizie o comunque non censite nel Registro degli Operatori di Comunicazione (Roc) per realizzare i contatti promozionali. Un fenomeno, avvertito dalla stessa Vodafone, che sembra ricondursi in massima parte ad un "sottobosco" di call center abusivi, che effettuano attività di telemarketing in totale spregio delle disposizioni in materia di protezione dei dati personali.

Ulteriori profili di violazione sono stati rilevati nella gestione delle liste dei nominativi da contattare acquisite da fornitori esterni. Liste che i partners commerciali di Vodafone avevano ricevuto da altre aziende e trasferito all'operatore telefonico senza il necessario consenso libero, informato e specifico degli utenti.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Sono risultate inadeguate anche le misure di sicurezza dei sistemi di gestione della clientela, profilo sul quale l'Autorità aveva già ricevuto numerosi reclami e segnalazioni da parte di clienti che erano stati contattati da sedicenti operatori Vodafone, i quali chiedevano l'invio di documenti di identità mediante Whatsapp, probabilmente con finalità di spamming, phishing o per la realizzazione di altre attività fraudolente.

Alla luce delle violazioni riscontrate, il Garante Privacy ha applicato una sanzione di 12.251.601,00 euro.".

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Le ultime sanzioni contro i giganti del web

Il 10 dicembre 2020 il CNIL ha imposto due sanzioni a Google (100 milioni) e Amazon (35 milioni) per mancato rispetto della normativa relativa alle informazioni da dare agli utenti sui cookie di tracciamento installati sui computer degli utenti. L'Autorità ha ritenuto che le informazioni fornite agli utenti francesi non consentissero di fornire un consenso consapevole e preventivo all'installazione dei cookie sui propri computer. Nella quantificazione delle sanzioni ha avuto rilevanza anche l'ammontare dei profitti che i colossi del web traggono dall'attività dei cookie di tracciamento.

Il 15 dicembre 2020 Twitter ha ricevuto la prima sanzione per violazione del GDPR da parte dell'Autorità garante irlandese (DPC), che ha comminato una multa di 450.000 euro. Il DPC ha infatti rilevato una violazione dei paragrafi 1 e 5 dell'articolo 33 del GDPR, riguardanti la notifica tempestiva di una violazione dei dati personali all'Autorità competente e gli obblighi di documentazione relativi al data breach.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Conti Giacomo, Serra Giordano, *GDPR, che cosa rivelano le prime sanzioni: ecco le scelte delle autorità di controllo*, pubblicato su AgendaDigitale il 27 marzo 2019
- De Cicco Diletta, *Conflitto di interessi del DPO, maxi multa del Garante belga a un'azienda*, pubblicato su Cybersecurity360 l'8 maggio 2020
- Bernardi Nicola, *Taxi violavano la privacy dei clienti con telecamere e registratori vocali a bordo delle vetture*, pubblicato su federprivacy.org il 1 giugno 2020
- Garante per la protezione dei dati personali, Provvedimento su data breach - 4 aprile 2019 [doc. web 9101974]
- Garante per la protezione dei dati personali, Il Garante privacy sanziona Eni Gas e Luce per 11,5 milioni. Telemarketing indesiderato e attivazione di contratti non richiesti [doc. web 9244351]
- Garante per la protezione dei dati personali, Marketing: dal Garante privacy sanzione di 27 milioni e 800 mila euro a Tim [doc. web 9256409]
- Garante per la protezione dei dati personali, Telemarketing aggressivo. Dal Garante privacy sanzione a Vodafone per 12 milioni 250 mila euro [doc. web 9485754]

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).